

中华人民共和国通信行业标准

XX XXXXX—XXXX

移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第 1 部分：总则

Application personal information collection and usage
minimization and necessity evaluation specification —
Part1: General principle

（报批稿）

XXXX – XX – XX 发布

XXXX – XX – XX 实施

目 次

前 言	III
引 言	IV
1 范围	5
2 规范性引用文件	5
3 术语和定义	5
4 缩略语	6
5 基本原则	6
6 最小必要评估要求	6
6.1 权限要求	7
6.2 告知同意要求	7
6.3 收集要求	7
6.4 存储要求	7
6.5 使用要求	8
6.6 加工要求	8
6.7 传输要求	8
6.8 提供要求	8
6.9 公开要求	8
6.10 删除要求	8
7 最小必要评估方法	8
7.1 权限要求评估方法	9
7.2 告知同意要求评估方法	11
7.3 收集要求评估方法	12
7.4 存储要求评估方法	12
7.5 使用要求评估方法	15
7.6 加工要求评估方法	17
7.7 传输要求评估方法	18
7.8 提供要求评估方法	18
7.9 公开要求评估方法	18
7.10 删除要求评估方法	19
8 最小必要评估流程	19
8.1 总体要求	19
8.2 评估方与被评估方	20

8.3 选择评估指标	20
8.4 制定评估计划	20
8.5 实施评估	20
8.6 评估结论	21

前 言

本文件按照GB/T 1.1—2020《标准化工作导则 第1部分：标准化文件的结构和起草规则》的规定起草。

请注意本文件的某些内容可能涉及专利。本文件的发布机构不承担识别专利的责任。

本文件由中国通信标准化协会提出并归口。

本文件起草单位：中国信息通信研究院、OPPO广东移动通信有限公司、华为技术有限公司、北京奇虎科技有限公司、高通无线通信技术(中国)有限公司、北京三快在线有限公司、北京字节跳动科技有限公司、北京三星通信技术研究有限公司、深圳荣耀智能机器有限公司、北京快手科技有限公司、北京京东尚科信息技术有限公司。

本文件主要起草人：宋恺、王艳红、杜云、武林娜、陈鑫爱、卜英华、周飞、李京典、李可心、宁华、刘陶、吴怡、常新苗、李腾、落红卫、王宇晓、刘陶、武林娜、王江胜、方强、衣强、姚一楠、李昞婧、吴越、赵晓娜、周圣炎、贾雪飞、李然。

引 言

随着移动应用种类和数量呈爆发式增长，APP侵害用户权益事件层出不穷，个人信息保护态势愈加严峻，如何保护个人信息，尤其是人脸、通讯录、短信、位置、图片等敏感个人信息受到政府机构和公众高度关注。APP收集使用个人信息最小必要评估旨在对移动互联网行业收集使用人脸、通讯录、短信、位置、图片等敏感个人信息进行规范，落实最小、必要的原则。YD/T XXXX由16个部分构成：

- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第1部分：总则；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第2部分：位置信息；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第3部分：图片信息；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第4部分：终端通讯录；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第5部分：设备信息；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第6部分：软件列表；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第7部分：人脸信息；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第8部分：录像信息；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第9部分：录音信息；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第10部分：通话记录；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第11部分：短信信息；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第12部分：好友列表；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第13部分：传感器信息；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第14部分：应用日志信息；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第15部分：身份信息；
- 移动互联网应用程序（APP）收集使用个人信息最小必要评估规范 第16部分：剪切板信息。

移动互联网应用程序（APP）收集使用个人信息最小必要评估规范

第1部分：总则

1 范围

本文件规定了APP收集使用个人信息的最小必要基本原则、评估要求、评估方法以及评估流程。

本文件适用于移动互联网应用程序（APP）收集使用个人信息的设计、开发和评估，个别条款不适用于特殊行业、专业应用，其他终端也可参考使用。

2 规范性引用文件

下列文件对于本标准的应用是必不可少的。凡是注日期的引用文件，仅注日期的版本适用于本标准。凡是不注日期的引用文件，其最新版本（包括所有的修改单）适用于本标准。

GB/T 35273-2020 《信息安全技术 个人信息安全规范》

3 术语和定义

下列术语和定义适用于本文件。

3.1

移动智能终端 smart mobile terminal

能够接入移动通信网，具有能够提供应用程序开发接口的操作系统，具有安装、加载和运行应用软件能力的终端。

3.2

移动互联网应用程序 mobile application software

可安装在移动智能终端内，能够利用移动智能终端操作系统提供的公开开发接口，实现某项或某几项特定任务的计算机软件，包含移动智能终端预置应用软件，小程序、快应用以及互联网信息服务提供者提供的可以通过网站、应用商店等移动应用分发平台下载、安装、升级的应用软件。

3.3

个人信息 personal information

以电子或者其他方式记录的与已识别或者可识别的自然人有关的各种信息，不包括匿名化处理后的信息。

[来源：《中华人民共和国个人信息保护法》]

3.4

敏感个人信息 sensitive personal information

一旦泄露或者非法使用，可能导致自然人的人格尊严受到侵害或者人身、财产安全受到危害的个人信息，包括生物识别、宗教信仰、特定身份、医疗健康、金融账户、行踪轨迹等信息，以及不满十四周岁未成年人的个人信息。

[来源：《中华人民共和国个人信息保护法》]

3.5

个人信息主体 personal information subject

个人信息所标识或者关联的自然人。

[来源: GB/T 35273-2020, 3.3]

3.6**个人信息的处理 personal information processing**

对个人信息执行的操作或操作集, 主要包括个人信息的收集、存储、使用、加工、传输、提供、公开、删除等活动。

3.7**收集 collect**

获取个人信息的活动。

3.8**告知同意 inform consent**

APP通过弹窗或产品界面等方式提示通知个人信息主体知晓其个人信息处理活动及其有关规则, 并获个人信息主体做出自愿、明确授权的行为。

3.9**业务功能 business function**

满足个人信息主体具体使用需求的服务能力。

注: 如地图导航、网络约车、即时通讯、网络社区、网络支付、新闻资讯、网上购物、快递配送、交通票务等。

[来源: GB/T 35273-2020, 3.17]

3.10**敏感权限 sensitive permissions**

涉及用户的个人信息或相关资源, 或者可能对用户存储的数据或其他应用的操作产生影响的权限, 通常系统不会默认授权, 需要用户授权使用。

3.11**定向推送 directional Push**

基于特定个人信息主体的网络浏览历史、兴趣爱好、消费记录和习惯等个人信息, 向该个人信息主体推荐或展示信息内容、提供商品或服务的搜索结果以及推送商业广告等活动。

注: 业务实践中, 定向推送也被称为个性化展示或个性化推荐。本文件中同时使用定向推送、个性化展示和个性化推荐, 具有相同含义。

4 缩略语

下列缩略语适用于本文件。

APP 移动互联网应用程序 Application

SDK 软件工具开发包 Software Development Kit

5 基本原则

APP个人信息的处理应遵循最小必要原则, 即处理个人信息应当具有明确、合理的目的, 应与处理目的直接相关, 采取对个人权益影响最小的方式。当APP提供的业务功能不在《移动互联网应用程序(APP)收集使用个人信息最小必要评估规范》”系列标准内, 同样应满足最小必要要求。

6 最小必要评估要求

6.1 权限要求

权限申请和使用应遵循最小必要原则，要求如下：

- a) 权限申请和使用的目的、方式、范围应遵循最小必要原则，不应超出业务功能的实际需要或合理关联，法律法规另有规定的除外。
- b) APP应申请与业务功能相关的权限，不应过度申请权限。如APP的业务功能中，不包含录音相关场景，则不应申请录音权限。
- c) APP申请敏感权限时，应同步告知权限使用的目的和用途。
- d) APP宜优先采用系统自身功能，代替调用相关敏感权限。如APP需要拨打电话功能时，可优先选择调用系统的电话界面，而不是申请电话权限。
- e) 不得以改善服务质量、提升使用体验和实施风险控制等为由，强迫个人信息主体授予权限。
- f) APP申请权限时需要在使用对应业务功能时申请，不应一揽子申请多个权限，不得默认、捆绑或使用其他手段变相欺骗、误导、强迫个人信息主体授予权限。
- g) 对于第三方SDK等外部代码的引用，APP应要求SDK其相关权限的申请同样满足最小必要原则，不得过度申请权限。

6.2 告知同意要求

告知同意应遵循最小必要原则，要求如下：

- a) 告知同意应遵循最小必要原则，即APP所提供产品或服务涉及多项业务功能的，处理个人信息时，宜按业务功能单项或分项获得个人信息主体同意，不应采用捆绑方式强迫个人信息主体一次性同意多种业务功能收集的个人信息。个人信息主体拒绝同意时，仅影响与所拒绝个人信息相关的业务功能的正常使用。
- b) 告知同意的时机及频率，宜在收集使用之前或收集使用之时的适当时机告知，增进个人信息主体对告知与所处理收集的个人信息之间关联性的理解。

6.3 收集要求

收集个人信息应遵循最小必要原则，要求如下：

- a) 收集个人信息的目的、方式、范围应遵循最小必要原则，不应超出业务功能的实际需要或合理关联，法律法规另有规定的除外。
- b) APP被授予权限后，权限使用应遵循最小必要原则，即应合理使用申请的权限，不应滥用权限，超频次、超范围、超精度收集个人信息。

6.4 存储要求

个人信息的存储包含本地存储和服务器远端存储，均应遵循最小必要原则，要求如下：

- a) 存储个人信息的目的、方式、范围应遵循最小必要原则，不应超出业务功能的实际需要或合理关联，法律法规另有规定的除外。
- b) 存储个人信息的类型及数量应遵循最小必要原则，不应超出业务功能的实际需要。
- c) 存储个人信息的时间应遵循最小必要原则，即存储个人信息的时间，应当为实现处理目的所必要的最短时间，在超出上述期限后，应对个人信息进行删除或匿名化处理。

注：对于保存在端侧的个人信息，只需对业务运行过程中产生的包含个人信息的临时文件，或过程文件指定删除时间，其它个人信息由用户自己管理和控制。

- d) 收集个人信息后，宜立即进行去标识化处理，并将可用于恢复识别个人的信息与去标识化后的信息分开存储。

e) APP如需在终端本地存储个人信息，则应将个人信息存储在受保护的文件区域，防止其他APP非授权访问。

f) 个人生物识别信息应在本地进行加密存储。如因业务需要确需传出终端的，应使用单向不可逆摘要算法进行摘要处理或使用高强度加密算法进行加密处理，且单独明确告知，用户选择同意后，方能传出终端。

6.5 使用要求

使用个人信息应遵循最小必要原则，要求如下：

a) 使用个人信息的目的、方式、范围应遵循最小必要原则，不应超出业务功能的实际需要，法律法规另有规定的除外。

b) 使用个人信息时，除目的所必需外，应消除明确身份指向性，避免精确定位到特定个人。

c) 使用个人信息进行定向推送应遵循最小必要原则，不应超出业务功能的实际需要。

d) 若APP定向推送功能使用了第三方的个人信息来源，应以个人信息处理规则等形式向个人信息主体明示业务功能使用第三方的个人信息进行定向推送，并向个人信息主体明示第三方的个人信息来源。

e) 使用个人信息进行定向推送应显著区分个性化展示和非个性化展示，显著区分的方式包括但不限于：标明“推荐”、“猜你喜欢”等字样，或通过不同的栏目、版块、页面分别展示等。

f) 使用个人信息进行定向推送应当同时提供关闭个性化展示的选项。此外，APP宜建立个性化展示所依赖的个人信息(如标签、画像维度等)的自主控制机制，保障个人信息主体调控定向推送展示相关性程度的能力。

6.6 加工要求

加工个人信息应遵循最小必要原则，要求如下：

a) 加工个人信息的目的、方式、范围应遵循最小必要原则，不应超出业务功能的实际需要或合理关联，法律法规另有规定的除外。

b) 间接获取个人信息后，进行加工处理形成新的个人信息并用于其他目的，需要告知，并再次征得个人信息主体的同意。

6.7 传输要求

传输个人信息的目的、方式、范围应遵循最小必要原则，不应超出业务功能的实际需要或合理关联，法律法规另有规定的除外。

6.8 提供要求

提供个人信息的目的、方式、范围应遵循最小必要原则，不应超出业务功能的实际需要或合理关联，法律法规另有规定的除外。

6.9 公开要求

公开个人信息的目的、方式、范围应遵循最小必要原则，不应超出业务功能的实际需要或合理关联，法律法规另有规定的除外。

6.10 删除要求

删除个人信息应遵循最小必要原则，超出存储期限后，应对个人信息进行删除或匿名化处理。

7 最小必要评估方法

7.1 权限要求评估方法

评估编号	7.1.1
评估项目	6.1 a)
评估要求	权限申请和使用的目的、方式、范围应遵循最小必要原则，不应超出业务功能的实际需要或合理关联，法律法规另有规定的除外。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，权限申请使用的目的、方式、范围的说明。 步骤2：使用测试工具检测APP运行过程中权限的申请与使用是否与告知一致，是否满足最小必要原则。
预期结果	在步骤2后，如APP权限的申请与使用与告知一致，且满足最小必要原则，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

评估编号	7.1.2
评估项目	6.1 b)
评估要求	APP只申请与业务功能相关的权限，不应过度申请权限。如APP的业务功能中，不包含录音相关场景，则不应申请录音权限。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，权限申请使用的目的、方式、范围的说明。 步骤2：检查APP运行过程是否过度申请权限，即申请其业务功能中含有不相关的权限。
预期结果	在步骤2后，如APP未申请与其业务功能不相关的权限，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

评估编号	7.1.3
评估项目	6.1 c)
评估要求	APP申请敏感权限时，应同步告知权限申请使用的目的和用途。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，权限申请使用的目的、方式、范围的说明。 步骤2：检查APP运行过程中，权限申请是否同步告知申请使用权限的目的和用途。
预期结果	在步骤2后，如APP在申请权限时，同步告知申请使用权限的目的和用途，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

评估编号	7.1.4
------	-------

评估项目	6.1 d)
评估要求	APP宜优先采用系统自身功能，代替调用相关敏感权限。如APP需要拨打电话功能时，可优先选择调用系统的电话界面，而不是申请电话权限。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中权限申请使用的目的、方式、范围的说明。 步骤2：检查APP运行过程中，是否存在申请使用敏感权限来代替系统自身功能的情况。
预期结果	在步骤2后，如APP不存在申请使用敏感权限来代替系统自身功能的情况，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

评估编号	7.1.5
评估项目	6.1 e)
评估要求	不得以改善服务质量、提升使用体验和风险控制等为由，强迫个人信息主体授予权限。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中权限申请使用的目的、方式、范围的说明。 步骤2：检查APP运行过程中，是否存在以改善服务质量、提升使用体验和风险控制等为由，强迫个人信息主体授予权限的情况。
预期结果	在步骤2后，如APP不存在强迫个人信息主体授予权限的情况，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

评估编号	7.1.6
评估项目	6.1 f)
评估要求	APP申请权限时需要在使用对应业务功能时申请，不应一揽子申请多个权限，不得默认、捆绑或使用其他手段变相强迫、诱导、误导个人信息主体授予权限。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中权限申请使用的目的、方式、范围的说明。 步骤2：检查APP运行过程中，是否一揽子申请多个权限，是否存在以默认、捆绑或使用其他手段变相强迫、诱导、误导个人信息主体授予权限的情况。
预期结果	在步骤2后，如APP不存在一揽子申请多个权限，强迫诱导误导个人信息主体授权权限的情况，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

评估编号	7.1.7
------	-------

评估项目	6.1 g)
评估要求	对于第三方SDK等外部代码的引用，APP要求SDK其相关权限的申请同样满足最小化原则，不得过度申请权限。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，其集成的第三方SDK权限申请使用的目的、方式、范围的说明。 步骤2：使用测试工具检测APP运行过程中其集成的第三方SDK权限的申请与使用是否与告知一致，是否满足最小必要原则。
预期结果	在步骤2后，如APP集成的第三方SDK权限的申请与使用与告知一致，且满足最小必要原则，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

7.2 告知同意要求评估方法

评估编号	7.2.1
评估项目	6.2 a)
评估要求	告知同意应遵循最小必要原则，即APP所提供产品或服务涉及多项业务功能的，处理个人信息时，宜按业务功能进行单项或分项获得个人信息主体同意，不宜采用捆绑方式强迫个人信息主体一次性同意多种业务功能收集的个人信息，个人信息主体拒绝同意时，仅影响与所拒绝个人信息相关的业务功能的正常使用。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，其提供产品或服务涉及的多项业务功能，以及收集个人信息的目的、方式、范围的说明。 步骤2：检查APP运行过程中，是否存在捆绑方式强迫个人信息主体一次性同意多种业务功能收集个人信息的行为。 步骤3：检查APP运行过程中，如个人信息主体拒绝APP收集某一业务功能相关的个人信息，是否影响APP其他功能的正常使用。 步骤3：
预期结果	在步骤1后，如存在捆绑方式强迫个人信息主体一次性同意多种业务功能收集个人信息的行为，则该项评估结果为“不符合要求”，否则，进行步骤3。 在步骤3后，如果存在个人信息主体拒绝某一业务功能相关个人信息授权，影响APP其他功能正常使用的行为，则该项评估结果为“不符合要求”，否则该项评估结果为“未见异常”，评估结束。
备注	--

评估编号	7.2.2
评估项目	6.2 b)
评估要求	告知同意的时机及频率，宜在收集使用之前或收集使用之时的适当时机告知，增进个

	人信息主体对告知与所收集的个人信息之间关联性的理解。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，收集个人信息的目的、方式、范围的说明。 步骤2：使用测试工具检测APP运行过程中，其告知同意的时机是否在收集之前或收集之时。
预期结果	在步骤2后，如APP告知同意的时机在收集个人信息之前或收集之时，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

7.3 收集要求评估方法

评估编号	7.3.1
评估项目	6.3 a)
评估要求	收集个人信息的目的、方式、范围应遵循最小必要原则，不应超出业务功能的实际需要或合理关联，法律法规另有规定的除外。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，收集个人信息的目的、方式、范围的说明。 步骤2：使用测试工具检测APP运行过程中收集个人信息的情况是否与告知一致，是否满足最小必要原则。
预期结果	在步骤2后，如APP收集使用个人信息与告知一致，且满足最小必要原则，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	

评估编号	7.3.2
评估项目	6.3 b)
评估要求	APP被授予权限后，权限使用同样应遵循最小必要原则，即应合理使用申请的权限，不应滥用权限，超频次、超范围、超精度调用权限。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，其集成的第三方SDK权限申请使用的目的、方式、范围的说明。 步骤2：使用测试工具检测APP运行过程中其集成的第三方SDK权限使用是否与告知一致，是否满足最小必要原则，是否存在超频次、超范围、超精度调用权限的行为。
预期结果	在步骤2后，如APP不存在超频次、超范围、超精度调用权限的行为，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

7.4 存储要求评估方法

评估编号	7.4.1
评估项目	6.4 a)
评估要求	存储个人信息的目的、方式、范围应遵循最小必要原则，不应超出业务功能的实际需要或合理关联，法律法规另有规定的除外。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，存储个人信息的目的、方式、范围的说明。 步骤2：使用测试工具检测APP，存储个人信息的情况是否与告知一致，是否满足最小必要原则。
预期结果	在步骤2后，如APP存储个人信息与告知一致，且满足最小必要原则，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	

评估编号	7.4.2
评估项目	6.4 b)
评估要求	存储个人信息的类型及数量应遵循最小必要原则，不应超出业务功能的实际需要。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，存储个人信息的目的、方式、范围的说明。 步骤2：使用测试工具检测APP，存储个人信息类型及数量是否满足最小必要原则，是否超出业务功能的需要。
预期结果	在步骤2后，如APP存储个人信息未超出业务功能的需要，且满足最小必要原则，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

评估编号	7.4.3
评估项目	6.4 c)
评估要求	存储个人信息的时间应遵循最小必要原则，即存储个人信息的时间，应当为实现处理目的所必要的最短时间，在超出上述期限后，应对个人信息进行删除或匿名化处理。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，存储个人信息的时间的说明。 步骤2：使用测试工具检测APP，存储个人信息时间是否满足最小必要原则，是否在超出存储期限后，对个人信息进行删除和匿名化处理。
预期结果	在步骤2后，如APP在超出存储期限后，对个人信息进行删除和匿名化处理，且满足最小必要原则，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。

备注	--
----	----

评估编号	7.4.4
评估项目	6.4 d)
评估要求	收集个人信息后，宜立即进行去标识化处理，并将可用于恢复识别个人的信息与去标识化后的信息分开存储。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，存储个人信息的目的、方式、范围的说明。 步骤2：使用测试工具检测APP，存储的个人信息是否进行去标识化处理，是否将可用于恢复识别个人的信息与去标识化后的信息分开存储。
预期结果	在步骤2后，如APP存储的个人信息进行去标识化处理，且是否将可用于恢复识别个人的信息与去标识化后的信息分开存储，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

评估编号	7.4.5
评估项目	6.4 e)
评估要求	APP如需在终端本地存储个人信息，则应将个人信息存储在受保护的文件区域，防止其他APP非授权访问。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，存储敏感个人信息的目的、方式、范围的说明。 步骤2：使用测试工具检测APP，存储的敏感个人信息是否存储在受保护的文件区域。
预期结果	在步骤2后，如APP存储的敏感个人信息存储在受保护的文件区域，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

评估编号	7.4.6
评估项目	6.4 f)
评估要求	生物特征数据应进行加密存储，存储于本地。如因业务需要确需传出终端的，应使用单向不可逆摘要算法或高强度加密算法进行加密处理，且单独明确提醒，用户选择同意后，方能传出终端。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，存储个人信息的目的、方式、范围的说明。 步骤2：检查APP运行过程中是否收集存储生物特征数据。 步骤3：使用测试工具检测APP，收集生物特征数据是否进行加密存储，是否进行本地存储。

	步骤4：使用测试工具检测APP运行过程中，是否存在传输生物特征数据的行为。 步骤5：APP传输的生物特征数据是否使用单向不可逆摘要算法或高强度加密算法进行加密处理，是否经过个人信息主体的单独同意。
预期结果	在步骤2后，如APP不收集存储生物特征数据，则该项评估结果为“未见异常”，否则进行步骤3。 在步骤3后，如果APP对收集的生物特征数据进行加密存储，且存储在本地，则该项评估结果为“未见异常”，否则进行步骤4。 在步骤4后，如果APP不存在传输生物特征数据的行为，则该项评估结果为“未见异常”，否则进行步骤5。 在步骤5后，如果APP对传输的生物特征数据使用单向不可逆摘要算法或高强度加密算法进行加密处理，且经过个人信息主体的单独同意，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

7.5 使用要求评估方法

评估编号	7.5.1
评估项目	6.5 a)
评估要求	使用个人信息的目的、方式、范围应遵循最小必要原则，不应超出业务功能的实际需要或合理关联，法律法规要求的除外。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，使用个人信息的目的、方式、范围的说明。 步骤2：使用测试工具检测APP，使用个人信息的情况是否与告知一致，是否满足最小必要原则。
预期结果	在步骤2后，如APP使用个人信息与告知一致，且满足最小必要原则，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

评估编号	7.5.2
评估项目	6.5 b)
评估要求	使用个人信息时，除目的所必需外，应消除明确身份指向性，避免精确定位到特定个人。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，使用个人信息的目的、方式、范围的说明。 步骤2：检查APP使用个人信息时，是否消除明确身份指向性，避免精确定位到特定个人。
预期结果	在步骤2后，如APP使用个人信息时消除明确身份指向性，避免精确定位到特定个人，

	则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

评估编号	7.5.3
评估项目	6.5 c)
评估要求	使用个人信息进行定向推送应遵循最小必要原则，不应超出业务功能的实际需要。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，使用个人信息进行定向推送的目的、方式、范围的说明。 步骤2：检查APP使用个人信息进行定向推送是否遵循最小必要原则，是否超出业务功能的实际需要。
预期结果	在步骤2后，如APP使用个人信息进行定向推送时，未超出业务功能的实际需要，且遵循最小必要原则，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

评估编号	7.5.4
评估项目	6.5 d)
评估要求	若APP定向推送功能使用了第三方的个人信息来源，应以个人信息处理规则等形式向个人信息主体明示业务功能使用第三方的个人信息进行定向推送，并向个人信息主体明示第三方的个人信息来源。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，使用个人信息进行定向推送的目的、方式、范围的说明。 步骤2：检查APP是否向个人信息主体明示第三方个人信息来源。
预期结果	在步骤2后，如APP使用第三方来源个人信息进行定向推送时，向个人信息主体明示第三方个人信息来源，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

评估编号	7.5.5
评估项目	6.5 e)
评估要求	使用个人信息进行定向推送应显著区分个性化展示和非个性化展示，显著区分的方式包括但不限于：标明“推荐”、“猜你喜欢”等字样，或通过不同的栏目、版块、页面分别展示等。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，使用个人信息进行定向推送的目的、方式、范围的说明。

	步骤2：检查APP页面中是否显著区分个性化展示和非个性化展示。
预期结果	在步骤2后，如APP显著区分个性化展示和非个性化展示，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	—

评估编号	7.5.6
评估项目	6.5 f)
评估要求	使用个人信息进行定向推送应当同时提供关闭个性化展示的选项。此外，APP宜建立个性化展示所依赖的个人信息(如标签、画像维度等)的自主控制机制，保障个人信息主体调控定向推送展示相关性程度的能力。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，使用个人信息进行定向推送的目的、方式、范围的说明。 步骤2：检查APP页面中是否提供关闭个性化展示的选项。
预期结果	在步骤2后，如APP提供关闭个性化展示的选项，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	—

7.6 加工要求评估方法

评估编号	7.6.1
评估项目	6.6 a)
评估要求	加工个人信息的目的、方式、范围应遵循最小必要原则，不应超出业务功能的实际需要或合理关联，法律法规另有规定的除外。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，加工相关的个人信息的目的、方式、范围的说明。 步骤2：检查APP后端数据和自声明，加工个人信息的情况，是否满足最小必要原则。
预期结果	在步骤2后，如APP加工个人信息的情况是否满足最小必要原则，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	—

评估编号	7.6.2
评估项目	6.6 b)
评估要求	间接获取个人信息后，进行加工处理形成新的个人信息并用于其他目的，需要告知，并再次征得个人信息主体的同意。
预置条件	被测APP处于正常运行状态

测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，加工相关的个人信息的目的、方式、范围的说明。 步骤2：检查APP后端数据，间接获取的个人信息是否征得数据主体的同意。
预期结果	在步骤2后，如APP间接获取的个人信息是否征得数据主体的同意，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

7.7 传输要求评估方法

评估编号	7.7.1
评估项目	6.7
评估要求	传输个人信息的目的、方式、范围应遵循最小必要原则，不应超出业务功能的实际需要或合理关联，法律法规另有规定的除外。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，传输个人信息的目的、方式、范围的说明。 步骤2：使用测试工具检测APP传输个人信息的情况是否满足最小必要原则。
预期结果	在步骤2后，如APP传输个人信息的情况满足最小必要原则，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

7.8 提供要求评估方法

评估编号	7.8.1
评估项目	6.8
评估要求	提供个人信息的目的、方式、范围，不应超出业务功能的实际需要或合理关联，法律法规另有规定的除外。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，提供个人信息的目的、方式、范围的说明。 步骤2：检查APP提供个人信息的情况是否与告知一致，是否满足最小必要原则。
预期结果	在步骤2后，如APP提供个人信息的情况与告知一致，满足最小必要原则，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

7.9 公开要求评估方法

评估编号	7.9.1
评估项目	6.9
评估要求	公开个人信息的目的、方式、范围应遵循最小必要原则，不应超出业务功能的实际需要或合理关联，法律法规另有规定的除外。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，公开个人信息的目的、方式、范围的说明。 步骤2：检查APP公开个人信息的情况是否与告知一致，是否满足最小必要原则。
预期结果	在步骤2后，如APP公开个人信息的情况与告知一致，满足最小必要原则，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

7.10 删除要求评估方法

评估编号	7.10.1
评估项目	6.10
评估要求	删除个人信息应遵循最小必要原则，超出存储期限后，应对个人信息进行删除或匿名化处理。
预置条件	被测APP处于正常运行状态
测试步骤	步骤1：打开被测APP，查看其隐私政策或其他相关个人信息收集使用规则文档中，删除个人信息的说明。 步骤2：检查APP后端数据，是否存在超期后，仍未进行删除或匿名化处理的个人信息。
预期结果	在步骤2后，如APP不存在超期后仍未删除和匿名化处理的个人信息，则该项评估结果为“未见异常”，否则该项评估结果为“不符合要求”，评估结束。
备注	--

8 最小必要评估流程

8.1 总体要求

APP收集使用个人信息最小必要评估流程应符合图1的规定。包括确定评估目标、选择评估指标、制定评估计划、实施评估及得出评估结论四个活动。

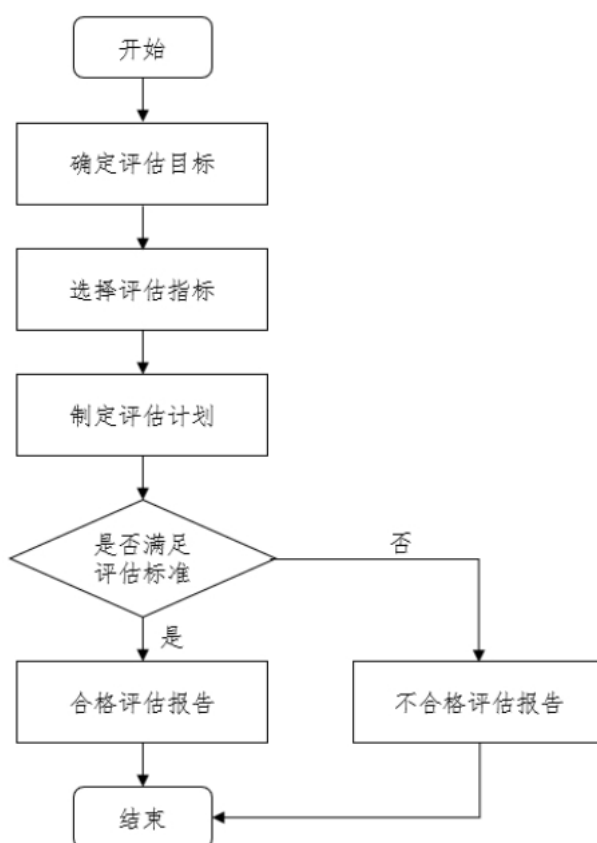


图1 APP收集使用个人信息最小必要评估流程图

8.2 评估方与被评估方

应考虑以下方面，确定评估方和被评估方：

- a) 被评估方可为APP或者APP中某项某类功能。
- b) 评估方可为APP提供者、开发者和运营者，也可为第三方实验室。

8.3 选择评估指标

应考虑以下方面，确定评估指标：

- a) 评估方根据被评估方提供的技术说明文档、被评估APP样品等材料，确定初步的方案审核，发现涉及的个人信息类型，选择对应的评估规范标准，并由此定义后续的评估的计划和评估项例。

8.4 制定评估计划

应考虑以下方面，制定评估准则：

- a) 评估方应根据评估目标，本着公平、公正、公开原则开展评估工作。
- b) 评估准则内容应至少包括评估对象和范围、评估依据、评估环境、评估工具。
- c) 评估准则中应明确评估通过/不通过准则。

8.5 实施评估

应考虑以下方面，实施评估工作：

- a) 依据对应的评估规范标准开展实施评估活动。
- b) 通过各部分实施评估工作可顺序开展也可并行开展，无完整的顺序关系。

c) 各部分最小必要评估结果均应以评估报告的形式进行输出，其内容至少应包括开展最小必要信息类型、评估所选择的评估指标及针对评估指标的评估结果。

8.6 评估结论

应考虑以下方面，给出评估结论：

a) 针对开展评估的个人信息类别进行评估，APP 收集使用最小必要未见异常并通过评估，否则未通过评估。

b) 在最小必要评估报告中，应包含评估的环境、评估基本要素和每一项评估的结果，同时还应具体描述评估过程中的步骤，如包含未通过项则评估报告中应包含未通过原因的具体描述。
